

ANÁLISIS DE SERVICIOS DE SEGURIDAD

Introducción

Al realizar un análisis en la índole de la ciberseguridad, es necesario el emplear normativas y estándares ya preestablecidos, entrando en juego el ITU-T X.800 el cual proporciona un modelo fundamental al definir los servicios de seguridad (autenticación, control de acceso, confidencialidad, integridad, no repudio y disponibilidad), sirviendo como base que nos permite identificar que cosas se ven comprometidas en la seguridad.

De misma manera el RFC 4949 (Internet Security Glossary), establece un glosario técnico que permite dar una mayor idea de la conceptualización a la hora de describir el caso que se presenta, un documento de apoyo, esencial para comprender el contexto que se llegue a presentar.

Análisis de Casos

<i>CASO</i>	<i>Servicios X.800 comprometidos</i>	<i>Definición(es) aplicable(s) RFC 4949.</i>	<i>Tipo de amenaza</i>	<i>Vector de ataque</i>	<i>Impacto técnico / operativo</i>	<i>Medida de control recomendada</i>
<i>01</i>	▪ Confidencialidad ▪ Integridad ▪ Disponibilidad ▪ Control de acceso.	▪ Ransomware: tipo de malware que cifra datos para exigir un rescate. ▪ Data Breach: divulgación no autorizada de información sensible. ▪ Multi-stage attack: ataque ejecutado en múltiples fases con distintos objetivos. ▪ Availability Attack: ataque que degrada o impide el acceso a sistemas o datos.	Externa	Acceso inicial no autorizado	▪ Cifrado dentro de los servidores ▪ Pérdida total de disponibilidad ▪ Exposición de información sensible ▪ Daño de reputación y legal	▪ Implementación de backups inmutables y offline ▪ Monitoreo continuo ▪ Segmentación de la red

02	▪ Confidencialidad ▪ Control de acceso	▪ Misconfiguration: configuración incorrecta de un sistema que expone recursos. ▪ Exposure: condición en la que la información queda accesible sin autorización.	No intencional	Acceso público directo a servicios	▪ Pérdida de confidencialidad de los datos ▪ Riesgos legales y regulatorios ▪ Daño de reputación	▪ Auditorías Periódicas De Configuración ▪ Validaciones Automáticas De Seguridad En La Nube. ▪ Controles De Acceso Por Defecto
03	▪ Integridad ▪ Confidencialidad - Control de acceso	▪ Supply Chain Attack: ataque que compromete componentes confiables para distribuir código malicioso ▪ Relationship Abuse: uso indebido de relaciones de confianza entre sistemas.	Externa	Actualización de software de un proveedor confiable (similar al caso NotPetya - 2017)	▪ Compromiso masivo de sistemas ▪ Pérdida de confianza en el proveedor	▪ Verificación de integridad después de instalación ▪ Segmentación de privilegios de aplicaciones
04	▪ Autenticación ▪ Control de acceso	▪ Credential Compromise: obtención no autorizada de credenciales válidas. ▪ Phishing: técnica de ingeniería social para robar información de autenticación. ▪ Authentication Failure: fallo del servicio de autenticación pese a su correcto funcionamiento técnico.	Externa	Campañas de phishing dirigidas a usuarios	▪ Acceso prolongado no autorizado ▪ Riesgo de escalamiento de privilegio	▪ Monitoreo de comportamiento de usuario ▪ Detección de accesos anómalos ▪ Concientización en seguridad.

05	Disponibilidad Integridad	▪ Data Destruction: eliminación o daño deliberado de datos. ▪ Availability Attack: acción destinada a impedir el acceso legítimo a sistemas o información.	Externa	Ejecución de ransomware con acceso previo	▪ Interrupción prolongada de operaciones ▪ Dependencia de reconstrucción en los sistemas.	▪ Implementación de respaldos offline ▪ pruebas periódicas de recuperación.
06	Confidencialidad, Control de acceso	▪ Insider Threat: amenaza originada por una entidad interna con acceso legítimo. ▪ Data Leakage: divulgación no autorizada de información sensible. ▪ Authorization Failure: asignación inadecuada de privilegios.	Interna	Uso indebido de accesos legítimo	▪ Pérdida de información sensible ▪ Consecuencias legales y reputacionales ▪ Deterioro de la confianza empresarial	▪ Aplicación del principio de mínimo privilegio ▪ monitoreo de actividades internas ▪ auditorías periódicas
07	Integridad No repudio	▪ Evidentiary Integrity: preservación de la validez probatoria de los datos. ▪ Audit Trail: registros que permiten reconstruir eventos de seguridad. ▪ Data Modification: alteración no autorizada de información.	Externa	Manipulación directa de registros del sistema	▪ Imposibilidad de reconstruir la secuencia de eventos ▪ Pérdida de evidencia digital ▪ Problemas en las investigaciones legales y forenses.	▪ centralización de registros ▪ Controles de integridad ▪ monitoreo continuo.

08	Disponibilidad	▪ Operational Failure: falla causada por errores internos en procesos o ejecución. ▪ Service Outage: interrupción no planificada de un servicio.	No intencional	Actualización de software mal ejecutada	▪ Interrupción masiva de servicios ▪ Afectación a operaciones críticas ▪ Pérdida de confianza en la estabilidad	▪ Pruebas previas en entornos controlados ▪ planes de rollback
09	Autenticación Confidencialidad	▪ Masquerade: suplantación de identidad de una entidad legítima. ▪ Social Engineering: manipulación de usuarios para eludir controles técnicos.	Externa	Correos electrónicos fraudulentos y sitios web falsos	▪ Compromiso de credenciales e información personal ▪ riesgo de accesos no autorizados posteriores	▪ Autenticación fuerte ▪ concientización de usuarios ▪ monitoreo de dominios fraudulentos.
10	Confidencialidad Integridad Disponibilidad	▪ Destructive Attack: ataque cuyo objetivo es causar daño irreversible. ▪ Data Exfiltration: extracción no autorizada de información. ▪ Data Destruction: eliminación deliberada de datos y sistemas.	Externa	Acciones destructivas ejecutadas tras acceso no autorizado	▪ Pérdida total de información y sistemas ▪ Imposibilidad de recuperación ▪ consecuencias operativas extremas	▪ Detección temprana ▪ segmentación de red ▪ controles de acceso estrictos ▪ respaldos inmutables

Conclusiones

Como podemos observar existe un sin número de posibilidades en las que un sistema se ve vulnerado, no solo por atacantes/ amenazas externas, si no, que incluso pueden ser no intencionales dentro de un mismo equipo, por lo que tener un enfoque y conciencia de las probables consecuencias existentes en estos ciberataques o problemas que pueden ocurrir es esencial para mantener los servicios de seguridad existentes, e incluso la base de la ciberseguridad, el modelo CIA (Confiability, Integrity and Dispobibilidad).

Referencias

- ITU-T. (1991). Recommendation X.800: Security Architecture for Open Systems Interconnection. International Telecommunication Union.
- IETF. (2007). RFC 4949 – Internet Security Glossary, Version 2. <https://datatracker.ietf.org/doc/html/rfc4949>